

# Chapitre 3

La mesure et l'évaluation des risques — corrigés

**Corrigé**

---

**Jaouad Madkour**

Faculté d'Économie et de Gestion de Tanger  
Exercices et corrigés · Risque opérationnel et résilience

# 1 Corrigés des exercices du chapitre

## Corrigé de l'exercice 1 — Les données de pertes : cercles concentriques, seuils réglementaires et événements

- (a) Le cercle central — la base de données de pertes — « aliment[e] les auto-évaluations (RCSA) au deuxième cercle » : les incidents réellement survenus nourrissent le jugement porté lors des ateliers de RCSA sur la probabilité et l'impact des risques. Ces RCSA sont ensuite « surveillées par des indicateurs clés de risque (KRI) au troisième cercle » : les KRI vérifient, entre deux exercices de RCSA, que l'évaluation qualitative reste cohérente avec la réalité opérationnelle observée. Le cercle extérieur — les leçons apprises des incidents majeurs — referme la boucle en « complét[ant] » l'ensemble, ces leçons alimentant à leur tour, indirectement, de nouveaux enregistrements dans la base de pertes. La base de données de pertes occupe nécessairement le centre car elle est la seule des quatre couches à reposer sur des faits déjà matérialisés (des pertes réellement survenues) plutôt que sur un jugement (RCSA), une mesure de tendance (KRI) ou une synthèse d'incidents majeurs déjà eux-mêmes enregistrés dans la base : toutes les couches externes se nourrissent, en dernière analyse, de cette couche factuelle centrale.
- (b) Un seuil de collecte interne inférieur au seuil réglementaire de 20 000 euros sert la gestion du risque car de nombreuses pertes de faible montant, bien qu'individuellement négligeables pour le calcul du capital, révèlent collectivement des défaillances de contrôle récurrentes (erreurs de saisie, échecs de procédure) dont la fréquence et la répétition constituent une information de gestion utile — typiquement pour alimenter les KRI ou identifier des contrôles à renforcer — indépendamment de tout enjeu de capital réglementaire. La tension révélée par la tendance à relever ces seuils est celle qui oppose l'exhaustivité de la collecte (plus le seuil est bas, plus l'information disponible pour la gestion est riche) à la charge opérationnelle qu'elle impose (documenter, catégoriser et faire vérifier un grand nombre d'incidents de faible montant mobilise des ressources sans apport proportionnel à la gestion du risque au-delà d'un certain volume) : la remontée des seuils traduit un arbitrage en faveur de la seconde contrainte, aux dépens d'une partie de la première.
- (c) Le traitement est asymétrique car le critère déterminant n'est pas la nature opérationnelle de la cause de la perte, mais l'absence de double comptage du capital réglementaire déjà exigé ailleurs : une perte de crédit d'origine opérationnelle est « déjà comptée dans les actifs pondérés de crédit », c'est-à-dire déjà couverte par le capital de Pilier 1 dédié au risque de crédit — l'inclure aussi dans la base de pertes opérationnelles reviendrait à exiger deux fois du capital pour la même perte. À l'inverse, rien dans le calcul du capital de marché ne couvre spécifiquement les pertes de marché dont la cause est opérationnelle : les inclure dans la base de pertes opérationnelles ne crée donc aucun double comptage, et permet au contraire de capturer, dans le capital minimal, un risque qui autrement échapperait à toute exigence de fonds propres. L'asymétrie préserve ainsi le principe selon lequel chaque euro de perte ne doit être couvert par du capital réglementaire qu'une seule fois, quelle que soit la catégorie de risque à laquelle on le rattache in fine.
- (d) Le texte libre compromet spécifiquement l'agrégation automatisée — et non la seule compréhension d'un incident isolé — car il ne peut être ni compté, ni sommé, ni trié par catégorie sans un travail d'interprétation humaine préalable, incompatible avec un traitement systématique portant sur des milliers d'incidents : une analyse agrégée (calcul de PD, de sévérité moyenne, de tendances par catégorie) exige des valeurs directement exploitables, ce que seuls les champs structurés garantissent, quelle que soit par ailleurs la richesse narrative que le texte libre peut apporter à la compréhension d'un cas particulier. Le recours à des sources externes à la base d'incidents (grand livre général, journaux P1/P2, provisions pour litiges, réclamations clients, presse négative) constitue un contrôle de *cohérence* plutôt qu'une simple source additionnelle car son objectif n'est pas d'enrichir le contenu de la base, mais de vérifier, par recoupement indépendant, que rien de matériel n'a échappé au processus de déclaration lui-même : un écart entre le nombre de litiges provisionnés au grand livre et le nombre d'incidents correspondants enregistrés dans la base signale un problème de *déclaration*, non un manque d'information sur un incident déjà connu — exactement le type de sous-déclaration que le cours identifie comme « un défi persistant, en particulier pour les petits établissements ».

## Corrigé de l'exercice 2 — L'évaluation qualitative : RCSA, carte de chaleur et indicateurs

- (a) La distinction entre risque inhérent et risque résiduel est indispensable car une mesure unique du risque ne permettrait pas de savoir si un niveau de risque observé est faible *parce que* le risque sous-jacent est intrinsèquement modéré, ou *parce que* des contrôles efficaces le réduisent fortement — deux situations appelant des priorités de gestion opposées (surveillance de routine dans le premier cas, vigilance sur la robustesse des contrôles dans le second, un contrôle défaillant faisant immédiatement remonter le risque résiduel vers le niveau inhérent). Exprimer l'impact en pourcentage du chiffre d'affaires ou des clients plutôt qu'en valeur absolue résout un problème de comparabilité car une perte de, par exemple, 500 000 euros représente un choc majeur pour une petite agence régionale mais un événement mineur pour une grande banque internationale : seule une mesure relative à la taille de l'entité (part du chiffre d'affaires, part de la base de clients) permet de comparer et d'agréger utilement des évaluations de risque conduites dans des entités de tailles très différentes au sein d'un même groupe.
- (b) Un risque « fréquent à faible impact » ( $1 \times 4$ ) — par exemple de petites erreurs de saisie répétées — appelle des contrôles préventifs de routine intégrés au processus quotidien et un budget d'exploitation courant pour absorber ces pertes récurrentes et prévisibles, car sa gestion relève de l'amélioration continue de processus établis. Un risque « rare à impact extrême » ( $4 \times 1$ ) — par exemple une cyberattaque majeure — appelle au contraire des plans de continuité d'activité, des scénarios de crise et un capital de réserve dimensionné pour un événement improbable mais potentiellement existentiel, car son improbabilité même interdit de se fier à l'expérience courante pour s'y préparer. Le produit arithmétique  $1 \times 4 = 4 \times 1$  étant strictement identique, un score numérique unique masquerait cette différence de traitement pourtant fondamentale : deux risques de « score » égal peuvent exiger des dispositifs de gestion entièrement disjoints.
- (c) Le vert appelle une « surveillance de routine » : aucune action corrective n'est requise, le risque évolue normalement à l'intérieur de l'appétit. Le jaune, « dans l'appétit mais en approche de la limite », appelle une vigilance accrue et un suivi plus rapproché, sans déclencher d'action corrective formelle. L'ambre, « au-dessus des niveaux acceptables », exige un « plan d'action requis » : une réponse de gestion documentée et suivie. Le rouge, « bien au-delà de l'appétit », exige une « action urgente », généralement portée au niveau de la direction générale ou du conseil. Une carte à deux couleurs perdrait la distinction entre le jaune et le rouge — c'est-à-dire l'information de *tendance* qu'apporte le code à quatre couleurs : le jaune signale un risque qui, sans être hors appétit, s'en approche et mérite d'être surveillé avant qu'il ne devienne un problème, une alerte précoce qu'un simple codage binaire acceptable/inacceptable ne pourrait pas transmettre puisque le jaune, comme le vert, serait alors classé « acceptable » sans distinction.
- (d) Exemple : un taux d'erreurs de rapprochement bancaire qui augmente fortement dans une unité de back-office. Ce même événement est simultanément un **KPI dégradé** — l'objectif opérationnel de rapprochements traités sans erreur dans les délais n'est plus atteint —, un **KRI d'alerte** — la hausse du taux d'erreurs signale une probabilité accrue de pertes opérationnelles futures (paiements mal exécutés, litiges clients) —, et un **KCI en échec** — le contrôle de rapprochement lui-même, censé détecter les anomalies avant qu'elles ne s'aggravent, ne fonctionne manifestement plus avec l'efficacité attendue. Cet exemple illustre, comme celui du cours, que « ces trois familles se recoupent largement » : la même donnée brute (le taux d'erreurs) alimente trois lectures de gestion différentes selon l'angle — performance, risque futur, ou efficacité du contrôle — sans qu'aucune des trois ne soit « la bonne » lecture à l'exclusion des autres.

## Corrigé de l'exercice 3 — Les modèles factoriels et la modélisation statistique (LDA)

- (a) La décomposition en cinq facteurs distincts rend l'estimation plus robuste et plus transparente qu'un jugement global car chaque facteur (P1 à P5) peut être évalué séparément à partir de données ou d'une expertise propres à son domaine — statistiques de succès d'hameçonnage, taux d'échec du pare-feu observé, taux d'ouverture de courriels suspects, taux de détection réseau, probabilité de sortie effective des données — alors qu'un jugement global demanderait d'estimer

directement, sans appui décomposable, la probabilité d'un scénario complexe rarement voire jamais observé dans l'établissement; la transparence vient de ce que chaque facteur, et l'hypothèse retenue pour le combiner, reste visible et discutable, alors qu'un jugement global agrège ces choix dans une seule estimation opaque. Exemple de deux conditions manifestement non indépendantes : P2 (échec du pare-feu) et P4 (échec des contrôles détectifs de surveillance réseau) sont susceptibles d'être fortement corrélées si les deux contrôles reposent sur la même équipe de sécurité informatique ou la même infrastructure technique sous-dimensionnée — un établissement dont le pare-feu est mal configuré a de bonnes chances d'avoir également négligé la surveillance réseau qui devait le compléter. Ignorer cette dépendance et multiplier naïvement  $P(P2) \times P(P4)$  comme si les deux événements étaient indépendants sous-estimerait la probabilité conjointe réelle, puisque la survenue de l'un rend l'autre plus probable qu'en cas d'indépendance — biaisant à la baisse l'estimation du risque du scénario complet.

- (b) Deux couches de défense chacune fiable à 95 % (taux de défaillance individuel de 5 %) dont les défaillances sont indépendantes offriraient, ensemble, un taux de défaillance combiné de seulement  $0,05 \times 0,05 = 0,25\%$  — une protection très supérieure à celle de chaque couche prise isolément. Mais si les deux contrôles reposent sur le même système informatique sous-jacent, leurs défaillances sont fortement corrélées : lorsque ce système tombe en panne ou est compromis, il est probable que les deux contrôles échouent *simultanément*, de sorte que le taux de défaillance combiné réel se rapproche du taux de défaillance de la couche la moins fiable (jusqu'à 5 % dans le cas extrême d'une corrélation parfaite) plutôt que du produit des deux taux individuels. C'est exactement la métaphore du fromage suisse : si les trous des deux tranches sont « alignés » par construction (même cause sous-jacente), superposer les tranches n'apporte presque aucune protection additionnelle, contrairement à ce que suggérerait, à tort, le calcul naïf sous hypothèse d'indépendance.
- (c) Chaîne de cinq « pourquoi » plausible : (1) Pourquoi l'intrusion réseau a-t-elle réussi ? Parce qu'une vulnérabilité connue du système a été exploitée. (2) Pourquoi cette vulnérabilité était-elle exploitable ? Parce que le correctif de sécurité disponible n'avait pas été déployé. (3) Pourquoi ce correctif n'a-t-il pas été déployé ? Parce que sa validation et son installation n'ont été confiées à personne de disponible au moment de sa publication. (4) Pourquoi personne n'était-il disponible pour cette tâche ? Parce qu'une seule personne de l'équipe informatique maîtrisait la procédure de déploiement des correctifs, et qu'elle était absente. (5) Pourquoi une seule personne maîtrisait-elle cette procédure ? Parce que l'équipe ne dispose pas d'une double compétence sur cette tâche critique — la cause racine identifiée par le cours. Cette cause racine (absence de double compétence) se prête mieux à un contrôle préventif durable qu'un simple correctif du symptôme (déployer la mise à jour manquante) car ce dernier ne traite que l'incident présent, laissant l'organisation exposée au prochain correctif urgent qui tombera pendant une absence similaire, tandis qu'exiger une double compétence documentée élimine structurellement le mécanisme causal qui a permis l'incident, quel que soit le correctif futur concerné.
- (d) Une loi de Poisson à un seul paramètre  $\lambda$  se justifie pour la fréquence car ce qui est modélisé est un *décompte* d'événements discrets et indépendants dans le temps (0, 1, 2, ... événements par an) — exactement le processus que la loi de Poisson formalise avec un minimum d'hypothèses, un seul paramètre suffisant à en caractériser entièrement la moyenne et la variance (égales à  $\lambda$ ). La sévérité, à l'inverse, est un *montant* continu qui ne peut être négatif, dont la distribution est fortement asymétrique (de nombreuses petites pertes, quelques pertes très importantes) : une loi log-normale, à deux paramètres, est nécessaire pour capturer à la fois cette asymétrie et cette absence de borne inférieure négative, ce qu'une loi simple à un paramètre ne pourrait pas faire pour une grandeur monétaire continue. L'hétérogénéité du risque opérationnel est en réalité la même raison profonde qui motive les deux choix : c'est parce que les pertes opérationnelles ne proviennent pas d'un mécanisme statistique unique et homogène (comme le nombre de sinistres automobiles dans un portefeuille homogène, par exemple) que le cours sépare d'abord fréquence et sévérité — deux dimensions de nature différente qu'un modèle joint unique masquerait — puis, pour la même raison, met en doute la capacité de l'EVT à extrapoler la queue de cette sévérité déjà hétérogène à partir d'un unique mécanisme statistique supposé homogène : la séparation fréquence/sévérité de la LDA et la réserve méthodologique

sur l'EVT répondent toutes deux, à deux étapes différentes de la modélisation, à la même hétérogénéité fondamentale du risque opérationnel. Les quatre inputs AMA se classent ainsi : **tournés vers le passé** — les données de pertes internes (ILD) et externes (ELD), qui « informent le passé » en enregistrant ce qui s'est déjà matérialisé; **tournés vers le futur** — les données de scénarios (SD) et les facteurs d'environnement d'affaires et de contrôle interne (BEICF), qui « informent le futur prospectif ». Une modélisation qui ne s'appuierait que sur ILD et ELD resterait structurellement incomplète car elle ne capturerait que des pertes déjà survenues, dans un environnement de contrôle et d'activité qui a pu changer depuis : elle serait aveugle à un risque émergent encore jamais matérialisé (nouveau produit, nouvelle technologie, nouvelle vulnérabilité), ou à une dégradation récente de l'environnement de contrôle qui rend les pertes passées moins représentatives du risque futur — exactement le défaut que SD et BEICF sont conçus pour corriger.

## 2 Corrigé de l'exercice cumulatif

### Corrigé de l'exercice 4 — La mesure et l'évaluation à la lumière du chapitre 2, du chapitre 1 et de l'introdu

- (a) Les deux citations décrivent bien un seul et même exercice observé à deux moments de son usage dans le cours : le chapitre 2 présente la RCSA au stade où elle sert encore à *repérer* des risques (« les participants réfléchissent collectivement aux risques et contrôles de leur activité », un exercice d'identification ascendante), tandis que ce chapitre en détaille l'usage au stade où elle sert à les *quantifier* en probabilité et en impact, avant et après contrôles (risque inhérent, risque résiduel). La formule du chapitre 2 — « mêle en pratique identification et évaluation » — annonçait déjà cette dualité car un atelier de RCSA ne peut, par construction, se limiter à *nommer* un risque sans immédiatement porter un jugement sur sa probabilité et son impact : la simple discussion collective qui fait émerger un risque produit du même mouvement une première estimation de sa gravité, rendant les deux étapes du cycle indissociables dans cet outil précis, à la différence d'autres outils (la cartographie des processus, par exemple) qui relèvent plus purement de la seule identification. Le rôle d'ORX change également de nature entre les deux chapitres : au chapitre 2, la base ORX sert à *repérer* des types de pertes externes que l'établissement n'a peut-être jamais connues, élargissant ainsi l'inventaire des risques identifiés; dans ce chapitre, cette même base sert à *calibrer numériquement* la queue d'une distribution statistique de sévérité, un usage qui exige des données bien plus comparables (mise à l'échelle, seuil de coupure, règles de filtrage) que le simple repérage qualitatif du chapitre 2. Ce second usage, plus exigeant, n'aurait aucun sens sans le premier : on ne peut calibrer statistiquement la queue de la distribution d'un risque que l'on n'a pas d'abord identifié comme faisant partie de l'inventaire des risques de l'établissement — la calibration présuppose la reconnaissance préalable du risque comme pertinent.
- (b) Le vert et le jaune situent un risque *dans* les limites d'appétit du chapitre 1 — respectivement loin des « seuils de fréquence et de sévérité des incidents tolérés » et en approche de ces mêmes seuils — tandis que l'ambre et le rouge signalent un dépassement de ces limites, à des degrés croissants de gravité (« au-dessus des niveaux acceptables » pour l'ambre, « bien au-delà de l'appétit » pour le rouge). Sans la déclaration d'appétit du chapitre 1, il ne resterait à la carte de chaleur de ce chapitre aucun repère objectif pour distinguer le vert de l'ambre : la carte de chaleur ne fait que *visualiser*, par un code couleur, une frontière entre acceptable et inacceptable que seule la déclaration d'appétit du chapitre 1 — ses limites d'exposition et ses seuils chiffrés — peut concrètement fixer; sans elle, la carte de chaleur resterait un outil de représentation vide de tout critère de jugement. De la même façon, la « méthode multicritère » de ce chapitre donne un contenu méthodologique concret à ce que le chapitre 1 ne fait que nommer : le chapitre 1 dit *que* le Pilier 2/ICAAP permet au régulateur « d'ajuster à la hausse le capital calculé en Pilier 1 », sans préciser *comment* ce supplément est calculé; ce chapitre répond précisément à cette question en indiquant que le supplément retenu doit excéder à la fois la perte du pire scénario isolé et celle d'une grappe de scénarios corrélés — transformant une notion institutionnelle abstraite (« le

régulateur peut exiger plus de capital ») en une règle de calcul opérationnelle que l'établissement peut effectivement appliquer dans son ICAAP.

- (c) Ce chapitre ajoute précisément à l'introduction la méthode qui manquait à sa seule définition conceptuelle : l'introduction établit *que* la résilience se pense par services opérationnels importants et par tolérances d'impact plutôt que par processus et délais de reprise, un choix de vocabulaire et de perspective ; ce chapitre établit *comment* on construit ce dispositif, à travers sept étapes précises allant de l'identification des IBS jusqu'à l'approbation par le conseil d'une auto-évaluation annuelle. Une organisation qui s'arrêterait à la seule définition de l'introduction ne pourrait pas valablement prétendre avoir adopté une démarche de résilience au sens du régulateur : connaître le vocabulaire (IBS, tolérances d'impact) sans avoir cartographié ses dépendances, testé des scénarios sévères, ni fait approuver une auto-évaluation par le conseil ne constitue qu'une adhésion nominale au concept, sans le dispositif opérationnel que le régulateur cherche précisément à vérifier lors de ses contrôles. Quant à la répétition de la citation du BCBS, elle intervient à la fin d'un chapitre entier consacré aux techniques de mesure — RCSA, arbres de défaillance, LDA, capital économique — précisément pour prévenir un contresens que ce même luxe de détail technique pourrait involontairement susciter chez le lecteur : celui de croire que la résilience serait un chantier de mesure supplémentaire et distinct, avec ses propres outils séparés du reste du dispositif de risque opérationnel, alors que le cours insiste sur le fait qu'elle n'est que la conséquence d'une gestion efficace de ce même dispositif déjà décrit — une mise en garde d'autant plus nécessaire que le lecteur vient de passer un chapitre entier à apprendre des techniques de mesure qui pourraient, prises isolément, laisser croire au contraire.
- (d) Les trois citations décrivent effectivement un seul et même passage de relais formulé à trois moments distincts du cours : l'introduction l'annonce *a priori*, en désignant à l'avance quel chapitre traitera quelle étape du cycle ; le chapitre 2 le reformule *a posteriori*, en désignant explicitement ce chapitre comme le destinataire de son propre travail (« l'étape suivante : l'évaluation, objet du chapitre 3 ») ; et ce chapitre le confirme à son tour dès son ouverture, en se situant lui-même très exactement à cet endroit du cycle (« après l'identification, ce chapitre couvre la deuxième étape »). L'évaluation de ce chapitre serait impossible à conduire sans l'inventaire des risques transmis par le chapitre 2 car chacun de ses outils présuppose un objet déjà identifié sur lequel s'exercer : la collecte des données de pertes exige de « rattache[r] chaque perte interne aux catégories d'événements de Bâle » — des catégories qui n'existent, concrètement pour l'établissement, que parce que le chapitre 2 a construit la taxonomie et l'inventaire correspondants ; la RCSA exige que les participants « réfléchissent [...] aux risques [...] de leur activité », ce qui suppose que ces risques aient déjà été nommés et cartographiés ; et l'analyse de scénarios ou les modèles factoriels (arbre de défaillance, bowtie) exigent un événement de risque déjà identifié à décomposer en facteurs causaux. Sans l'inventaire préalable du chapitre 2, la collecte des données de pertes n'aurait aucune catégorie à laquelle rattacher un incident, la RCSA n'aurait aucun risque nommé sur lequel porter un jugement de probabilité et d'impact, et l'analyse de scénarios n'aurait aucun événement de risque à placer au centre de son nœud papillon : les trois piliers de ce chapitre portent tous, structurellement, sur la matière que le chapitre 2 leur a livrée.

### 3 Corrigé des applications en sciences économiques

#### Corrigé de l'exercice 5 — Fréquence, sévérité et capital économique par la LDA, chiffrés

On a  $\lambda = 6$  événements par an et quatre bandes de sévérité  $(v_i, p_i)$  : (25, 55 %), (100, 30 %), (500, 12 %), (3 000, 3 %), en milliers d'euros.

- (a) La sévérité moyenne par événement est  $25 \times 0,55 + 100 \times 0,30 + 500 \times 0,12 + 3\,000 \times 0,03 = 13,75 + 30,00 + 60,00 + 90,00 = \mathbf{193,75}$  k€. La perte annuelle attendue est  $EL = \lambda \times 193,75 = 6 \times 193,75 = \mathbf{1\,162,50}$  k€, soit environ 1,16 million d'euros.
- (b) La contribution de chaque bande à la perte attendue de 193,75 k€ par événement est : Bande 1

=  $13,75/193,75 = 7,10\%$ ; Bande 2 =  $30,00/193,75 = 15,48\%$ ; Bande 3 =  $60,00/193,75 = 30,97\%$ ; Bande 4 =  $90,00/193,75 = 46,45\%$ . La bande de queue domine effectivement la perte attendue : avec seulement 3 % de probabilité, elle contribue à elle seule à près de la moitié (46,45 %) de la sévérité moyenne — davantage que les trois autres bandes réunies ne le feraient si l'on retirait la bande 4. Ce résultat illustre précisément le caractère « asymétrique et à queue épaisse » de la sévérité : un petit nombre d'événements rares et extrêmes pèse, en espérance, autant sinon plus que la multitude des événements fréquents et modérés, ce qui interdit de négliger la modélisation de la queue au seul profit du corps de la distribution.

- (c) Le capital économique est le 99,9<sup>e</sup> centile de la distribution agrégée simulée, soit **18 400 k€**. Rapporté à la perte annuelle attendue de 1 162,50 k€, ce capital représente un multiple de  $18\,400/1\,162,50 = 15,83$  fois la perte moyenne. Ce multiple élevé est cohérent avec l'exigence de couvrir des pertes « dans 999 années sur 1 000 » : un événement aussi rare que le pire centième de millième des scénarios simulés s'écarte nécessairement très fortement de la perte moyenne, la queue épaisse de la sévérité (mise en évidence au (b)) amplifiant encore cet écart par rapport à ce qu'une distribution à queue fine aurait produit pour le même centile.
- (d) Le pire scénario isolé est la pandémie, à 12 000 k€. La grappe retenue (pandémie + cyberattaque) s'élève à  $12\,000 + 9\,500 = 21\,500$  k€. Le capital multicritère est le maximum des deux, soit  $\max(12\,000, 21\,500) = 21\,500$  k€. Comparé au capital économique LDA de 18 400 k€, le capital multicritère lui est supérieur de  $21\,500 - 18\,400 = 3\,100$  k€, soit  $3\,100/18\,400 = 16,85\%$  de plus. La banque devrait retenir le montant le plus élevé des deux méthodes, soit 21 500 k€ pour son ICAAP : la logique même du Pilier 2 est de s'assurer que le capital détenu couvre le risque quelle que soit l'approche de mesure retenue, et une banque prudente ne saurait se contenter du montant le plus faible des deux approches lorsque l'autre, tout aussi fondée méthodologiquement, en indique un plus élevé — retenir le maximum des deux évite qu'un choix de méthode, plutôt que le profil de risque réel, ne détermine le niveau de capital détenu.

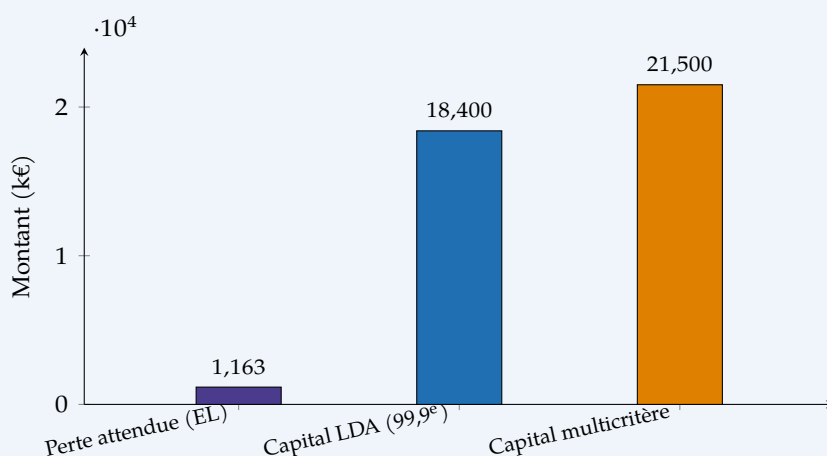


FIG. 1 : Perte annuelle attendue, capital économique LDA (99,9<sup>e</sup> centile) et capital multicritère ICAAP (grappe pandémie + cyberattaque) — exercice 5.

## Corrigé de l'exercice 6 — Tolérances d'impact, points de défaillance uniques et analyse d'impact sur l'act

On a quatre IBS avec (tolérance, durée estimée) en heures : Paiements domestiques (4, 7), Retraits GAB (24, 18), Courtage en ligne (8, 15), Service client (12, 9).

- (a) Paiements domestiques : écart =  $7 - 4 = +3$  h, soit  $3/4 = 75,00\%$  de la tolérance — **DÉPASSEMENT**. Retraits GAB : écart =  $18 - 24 = -6$  h, soit  $-25,00\%$  — dans la tolérance. Courtage en ligne : écart =  $15 - 8 = +7$  h, soit  $7/8 = 87,50\%$  de la tolérance — **DÉPASSEMENT**. Service client : écart =  $9 - 12 = -3$  h, soit  $-25,00\%$  — dans la tolérance.
- (b) Les deux IBS en dépassement, classées par sévérité relative décroissante, sont : le courtage en ligne (87,50 % de dépassement) en premier, puis les paiements domestiques (75,00 %). Selon les

sept étapes de la démarche de résilience, c'est le courtage en ligne qui devrait être prioritaire pour « un plan de communication interne et externe », puisque c'est l'IBS dont la tolérance est proportionnellement la plus dépassée sous le scénario testé — le préjudice y étant, toutes choses égales par ailleurs, jugé le plus sévère au regard du seuil que la banque s'était elle-même fixé.

- (c) L'espérance de perte annuelle sans redondance est  $0,03 \times 45\,000 = 1\,350$  k€. Avec redondance, elle tombe à  $0,005 \times 45\,000 = 225$  k€. La réduction de perte attendue est  $1\,350 - 225 = 1\,125$  k€ par an. Le bénéfice net de l'investissement, coût de 2 200 k€ par an déduit, est  $1\,125 - 2\,200 = -1\,075$  k€ : sur ce seul critère de perte attendue, l'investissement en redondance n'est **pas** rentable, son coût annuel excédant largement la réduction de perte espérée qu'il permet. Ce calcul en perte attendue ne justifie donc pas, à lui seul, l'investissement : le cours affirme au contraire que les SPOF « constituent des indicateurs clés de résilience à surveiller en priorité, et à éliminer par la redondance lorsque c'est possible », une prescription qui va au-delà du seul calcul de perte attendue — un point de défaillance unique expose l'établissement à un risque de queue et à un préjudice pour la continuité même du service (au-delà de son seul coût financier moyen), une dimension que l'espérance mathématique, en lissant les probabilités et les montants, tend structurellement à sous-pondérer par rapport à l'objectif réglementaire de résilience.
- (d) La tolérance d'impact qu'impliquerait l'appétit pour le risque est  $5\,000/900 = 5,56$  heures (arrondi). Comparée à la tolérance de 8 heures effectivement fixée pour le courtage en ligne, cette tolérance actuelle est **moins** conservatrice que ce que l'appétit pour le risque justifierait : 8 heures de tolérance autoriseraient, au coût de 900 k€ par heure donné par la BIA, un impact financier de  $8 \times 900 = 7\,200$  k€, soit 2 200 k€ de plus que le plafond de 5 000 k€ que la banque s'est elle-même fixé comme appétit maximal. Cette incohérence suggère que la banque devrait soit resserrer la tolérance d'impact du courtage en ligne à environ 5,6 heures pour l'aligner sur son appétit déclaré, soit investir dans des mesures qui réduisent le coût marginal de 900 k€ par heure de perturbation — l'analyse d'impact sur l'activité ayant précisément pour rôle, selon le cours, d'« aliment[er] directement les tolérances d'impact », ce qui suppose une cohérence entre le chiffrage de la BIA et le niveau de tolérance effectivement retenu.

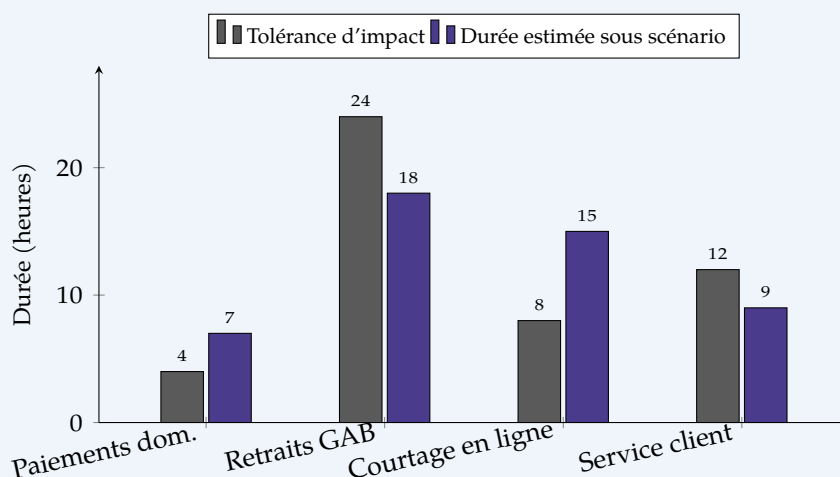


FIG. 2 : Tolérance d'impact et durée de perturbation estimée sous scénario sévère, par service opérationnel important (IBS). Le courtage en ligne et les paiements domestiques dépassent leur tolérance ; les retraits GAB et le service client restent en deçà — exercice 6.